

Módulo 12 — Seguridad en IA

OWASP LLM Top 10, prompt injection en capas, data poisoning, content filtering, seguridad agéntica y red teaming.

BLOQUE 1 · EL PANORAMA DE SEGURIDAD EN SISTEMAS DE IA

Módulo 12 — Seguridad en IA

La seguridad de los sistemas de IA difiere fundamentalmente de la seguridad del software tradicional. En el software tradicional, los ataques explotan vulnerabilidades en el código (buffer overflows, SQL injection, XSS) que son deterministas y reproducibles. En los sistemas de IA, los ataques ocurren en lenguaje natural, los comportamientos son probabilísticos (no deterministas), y la superficie de ataque incluye no solo el código sino también los datos de entrenamiento, los prompts del sistema, y las herramientas disponibles para el agente. Un atacante que consigue manipular el comportamiento de un agente con acceso a herramientas poderosas puede causar daños reales en sistemas de producción sin necesidad de explotar ninguna vulnerabilidad de código.

Los costes del cibercrimen alcanzaron 9.5 billones de dólares en 2024 y se proyectan superiores a 10.5 billones en 2025. Las vulnerabilidades de LLMs contribuyen crecientemente a esta tendencia. El OWASP Top 10 para aplicaciones LLM, publicado en 2023 y actualizado en 2025, es la referencia de la industria para la seguridad de aplicaciones de IA generativa. La seguridad de los sistemas de IA es también un requisito legal: el AI Act europeo (artículo 15) requiere robustez y ciberseguridad continua para sistemas de alto riesgo.

El OWASP Top 10 para LLMs 2025

El OWASP LLM Top 10 2025 lista las diez vulnerabilidades críticas de las aplicaciones LLM. LLM01 (Prompt Injection, #1 por segundo año consecutivo): manipulación del comportamiento del LLM a través del input del usuario o de datos procesados. LLM02 (Sensitive Information Disclosure, subió al #2 en 2025): el LLM revela información confidencial del system prompt, datos de otros usuarios, o información de entrenamiento privada. LLM03 (Supply Chain): dependencias comprometidas en modelos base, datasets, o librerías. LLM04 (Data and Model Poisoning): manipulación de los datos de entrenamiento para introducir backdoors. LLM05 (Improper Output Handling): pasar outputs del LLM sin sanitizar a sistemas downstream. LLM06 (Excessive Agency): el agente tiene más permisos de los necesarios. LLM07 (System Prompt Leakage): el system prompt confidencial se revela al usuario. LLM08 (Vector and Embedding Weaknesses): vulnerabilidades en sistemas RAG. LLM09 (Misinformation): el LLM genera contenido falso como factual. LLM10 (Unbounded Consumption): el sistema no limita el consumo de recursos. Las cinco nuevas entradas en 2025 (LLM06-LLM10) reflejan la madurez de los sistemas agénticos y RAG en producción.

Prompt injection: el riesgo número 1

La prompt injection es inherente a cómo funcionan los LLMs: el modelo no distingue entre instrucciones del sistema y inputs del usuario de la misma forma que un sistema operativo distingue entre código privilegiado y código de usuario. Todo llega como texto en el mismo espacio de tokens. Las técnicas más efectivas documentadas son: el roleplay injection (ASR del 89.6%: instruir al modelo a actuar como un personaje sin restricciones), los logic traps (ASR del 81.4%: explotar dilemas morales para

eludir filtros), y los encoding tricks (ASR del 76.2%: Base64, Unicode especial). El paper de octubre 2025 con investigadores de OpenAI, Anthropic, y Google DeepMind demostró que el 90% de las defensas publicadas pueden eludirse con ataques adaptativos. La defensa correcta es en capas: separación de instrucciones y datos + validación de input + controles en la capa de ejecución + HITL para acciones irreversibles + monitorización continua.

BLOQUE 2 · DATA POISONING, JAILBREAKS, Y SEGURIDAD AGÉNTICA

Vulnerabilidades avanzadas y estrategias de defensa

Data poisoning y supply chain de modelos

Los ataques de data poisoning introducen información maliciosa en los datos de entrenamiento para manipular el comportamiento del modelo. El poisoning en fine-tuning es especialmente peligroso porque los datasets de fine-tuning son pequeños (1% de los datos = 10 ejemplos maliciosos en un dataset de 1.000). Los backdoor attacks introducen triggers ocultos que activan comportamientos específicos del modelo solo cuando reciben el patrón de activación. PoisonGPT (Mithril Security, 2023) demostró que es posible modificar quirúrgicamente los pesos de un LLM para que genere información falsa específica en respuesta a preguntas específicas, pasando todos los benchmarks estándar. Los modelos en formato pickle en Hugging Face pueden contener código malicioso que se ejecuta al cargar el modelo (JFrog, 2024, encontró decenas de estos modelos). Las defensas incluyen: usar siempre el formato safetensors (no permite ejecución de código), verificar el hash SHA-256 de los modelos descargados, usar ModelScan de ProtectAI para escanear modelos antes de desplegarlos, y versionar los datasets con DVC.

Content filtering y validación de outputs

La validación de outputs es la última línea de defensa antes de que la respuesta llegue al usuario. Las tres dimensiones son: content filtering (detectar y bloquear outputs en categorías prohibidas: hate speech, violence, dangerous activities), structural validation (verificar que el output cumple el schema esperado: JSON válido con los campos correctos), y semantic validation (verificar que el contenido es factualmente correcto y relevante para la consulta). Las herramientas principales son: LlamaGuard de Meta (modelo clasificador local 1B-8B, bajo coste de operación), Azure Content Safety y Perspective API de Google (SaaS, fácil integración), y Guardrails AI (validaciones programáticas con reintentos automáticos). La arquitectura "sandwich" (LlamaGuard input + LLM + LlamaGuard output) proporciona cobertura tanto de ataques de input como de fallos de output.

Seguridad en sistemas agénticos

Los sistemas agénticos amplían dramáticamente la superficie de ataque: los agentes tienen herramientas que modifican el estado del mundo real. Las amenazas específicas son: memory poisoning (introducir información falsa en la memoria del agente para influir en decisiones futuras), tool misuse (un agente comprometido invocando herramientas con parámetros maliciosos), privilege escalation (usar una herramienta de bajo privilegio para acceder a herramientas de alto privilegio), y SSRF via tool de URL fetch (usar la herramienta de búsqueda web del agente como proxy para acceder a servicios internos protegidos). La regla Meta (octubre 2025): los controles de seguridad deben vivir fuera del LLM, en la capa de ejecución de herramientas. Cualquier seguridad implementada solo en el prompt puede ser eludida con prompt injection.

Red teaming y Secure AI Development Lifecycle

El red teaming de IA simula ataques adversariales para encontrar vulnerabilidades antes que los atacantes reales. Las herramientas automatizadas más usadas son Garak (NVIDIA, open source), DeepTeam (Confident AI, noviembre 2025), PyRIT (Microsoft, open source), y Promptfoo. Los cinco vectores que el red team debe cubrir son: prompt injection directa e indirecta, extracción de información sensible (system prompt, datos de otros usuarios), jailbreak para contenido dañino, abuso de herramientas y agencia excesiva, y DoS por consumo. El Secure AI Development Lifecycle (Secure AI DLC) integra la seguridad en cada fase: diseño (threat modeling con STRIDE), desarrollo (prompts como código, DVC para datasets, ModelScan para dependencias), y testing (golden dataset adversarial en CI/CD). El mandato regulatorio del red teaming es creciente: el EU AI Act artículo 15 y el Executive Order 14110 de EE.UU. lo establecen como requisito.

RESUMEN EJECUTIVO DEL MÓDULO 12: La seguridad de IA es fundamentalmente distinta al software: los ataques son en lenguaje natural, los comportamientos son probabilísticos, y la superficie incluye datos, modelos, prompts, y herramientas. El OWASP LLM Top 10 2025 tiene 10 vulnerabilidades críticas; las 5 nuevas reflejan la madurez de los sistemas agénticos. Prompt injection (ASR 89.6% para roleplay) es el riesgo #1 y es estructural, no un bug: requiere defensa en 5 capas. Data poisoning incluye backdoors en fine-tuning y supply chain (modelos pickle con malware): usar safetensors + ModelScan + DVC. Content filtering "sandwich" (LlamaGuard input + LLM + LlamaGuard output) protege tanto contra ataques como contra fallos. La seguridad agéntica requiere controles en la capa de ejecución, no solo en el prompt (regla Meta oct 2025). Red teaming con Garak/DeepTeam en CI/CD es el estándar del Secure AI DLC.